

The CISO's briefing: The value of ISO 27001 certification

✓ The question that always comes after the choice



Session objectives

By the end of this sequence:

- **Explain** what an ISO/IEC 27001 certification is as a mechanism: who audits, who certifies, who watches the certifiers
- **Analyse** a certification scope and say why two certificates against the same framework do not have the same value

- **Evaluate** the strategic value of a certification for a group: what it proves to a client, what it will never prove to a regulator
- **Answer** a hurried senior management without promising what the group's actual state does not yet allow to be promised

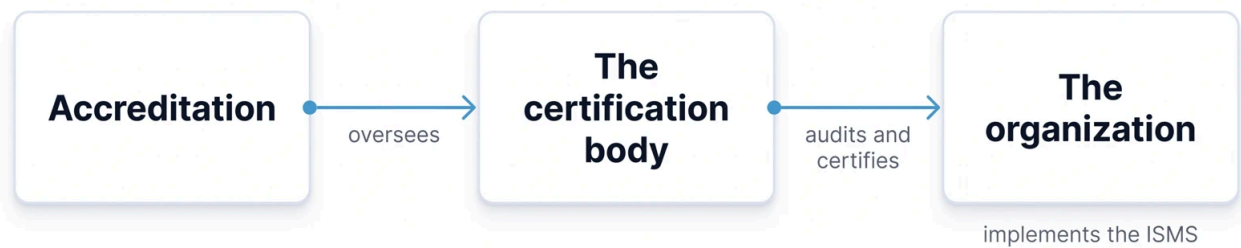
Prerequisites

- The framework choice settled in session 3: ISO/IEC 27001:2022 is the MERIDIAN group's backbone, and the business case note had it approved.
- What certification attests and does not attest, seen in session 3: a third party, a management system, a scope; and no presumption of NIS 2 compliance.
- The governance established in session 1: Executive Management sets the risk appetite, the Executive Committee approves the budgets, the Group CISO designs and arbitrates.

What to know before the exercise

Three additions are enough to handle the day's case. The rest, how an audit is actually conducted, is the business of this morning's lecture.

First, the mechanics of **ISO/IEC 27001 certification**, whose value has been known since session 3 but not yet its plumbing. The problem it solves is a problem of trust at scale: any organization can declare "our security is well managed", and that declaration is worth nothing, precisely because it costs nothing. Certification replaces the declaration with a proof: a **certification body**, third-party and independent, comes to audit the management system against the requirements of the standard and issues, if the audit concludes that it conforms, a certificate that commits the body's own reputation. The mechanics have one more storey, and it is what makes the edifice credible: certification bodies are themselves controlled. The ISO/IEC 27006 standard sets, in addition to ISO/IEC 17021, the requirements applicable to bodies that audit and certify ISMSs, and serves as the basis for their **accreditation** process: the certifier must prove its competence and impartiality before having the right to certify others. The three-link chain, to remember: the organization implements, the certification body audits and certifies, accreditation watches the certifiers. The limit of the mechanism, already known: it attests a management system over a scope, at a date; it guarantees no server, and it replaces no legal obligation.



Next, the **certification scope**, which must now be looked at as a strategist and no longer merely as a reader. The certificate covers what the organization has chosen to put into it: an activity, a site, a subsidiary, a whole group. This choice is the first economic and political trade-off of any certification project, because the effort grows with the scope, and so does the value, but not at the same rate. A narrow scope gets certified faster and reassures less; a broad scope impresses and can swallow two years of energy. The practical consequence, in one sentence inherited from session 3: faced with a certificate, read the scope before the date; faced with a certification project, draw the scope before the calendar.

Narrow scope

Gets certified faster

Reassures less

Broad scope

Impresses the market

Can swallow two years
of effort

Effort grows with scope, value too, but not at the same pace

Finally, the **strategic value**, that is, what the certificate changes in the group's balance of power. It comes down to three effects. Commercial effect: the certificate is defensible proof in a call for tenders, which avoids answering fifty security questionnaires a year, or at least shortens them. Rarity effect: according to AFNOR (the French standardization body), drawing on the ISO Survey, France had just over a thousand ISO 27001 certified organizations at the end of 2023, three times more than in 2019; being certified remains distinctive, and the momentum, already visible in 2020 with increases of 11 % in France and 22 % worldwide, says that competitors are getting on board. Internal effect, the least visible and the most durable: the deadline of an external audit disciplines an organization like no internal memo does. And the limit, learned in session 3 and never repeated enough in committee: certification does not amount to regulatory compliance. ANSSI's NIS 2 FAQ writes it bluntly: « L'obtention d'une certification ISO 27001 ne permet pas, en elle-même, une conformité à NIS 2. » (obtaining ISO 27001 certification does not, in itself, deliver compliance with NIS 2.) What the French framework grants it is narrower and more useful: the possibility of relying on it for ONE objective, governance, on the systems covered by the certification.

1,000+

ISO 27001 CERTIFIED
ORGANISATIONS IN FRANCE
AT THE END OF 2023: BEING
CERTIFIED REMAINS
DISTINCTIVE

AFNOR, drawing on the ISO Survey

x 3

GROWTH IN FRENCH
CERTIFIED ORGANISATIONS
BETWEEN 2019 AND THE END
OF 2023

AFNOR, drawing on the ISO Survey

+22 %

WORLDWIDE RISE IN
CERTIFICATIONS AS EARLY
AS 2020, +11 % IN FRANCE:
COMPETITORS ARE GETTING
ON BOARD

ISO Survey, 2020

💡 When the Group CISO is asked "how much does a certification cost" or "how long does it take", the only professional answer before a measured state of play is: "it depends on the scope and on the gap between what we claim and what we do, and I will be able to measure that gap this week". A figure thrown out before the initial audit is a debt.

✓ Case study: the third party demands a certificate, senior management wants the whole group

Scenario and problem statement

Monday morning. Two messages await the Group CISO, and they do not say the same thing.

The first comes from the Managing Director of the subsidiary under review: the third party which, in its subsidiary pack (map of power, section 3), asks it for evidence of security, or whose request the subsidiary dreads, has just spelled out its request, and it takes the classic form of a questionnaire that opens with "Are you ISO/IEC 27001 certified? If yes, attach the certificate and its scope. If not, describe the equivalent evidence." The Managing Director asks what to answer so as not to lose the third party.

The second comes from the Chief Executive Officer, who has read the session 3 business case note: "The committee has approved your standard. So let's see it through: I want the group certified, all subsidiaries, and fast. Tell me what stands in our way."

The Group CISO has the approved framework choice, the session 2 mapping, the framework imported into the GRC tool with a still-blank compliance assessment, and no measured state of play: the group's initial audit begins precisely today.

Guided questions

1. **Analyse** the third party's question, once it has been identified in the subsidiary pack: what is it seeking to obtain by asking for the certificate AND its scope, and why is the phrase "equivalent evidence" an honourable way out for MERIDIAN? List three existing pieces of evidence of the group's that can stand in for it today.
2. **Evaluate** the Chief Executive Officer's request: what are the two debatable assumptions in the sentence "the group certified, all subsidiaries, and fast"? Lean on what a scope costs and on what remains unknown about the group's actual state.
3. **Propose** a scope sequencing defensible in committee: which subsidiary or which activity is the first candidate, and why? Justify with the session 2 mapping and each subsidiary's regulatory context, not with a preference.

4. **Correct** the enthusiasm of the Chief Financial Officer, who concludes in a meeting: "If we are certified, NIS 2 is settled, we might as well budget it as a compliance project." Draft the clarification in three sentences, legally accurate and usable before a committee.
5. **Formulate** the answer to the third party in one paragraph: without a certificate today, without promising a date, but without leaving the box empty.

Working method

Handle the questions in order: the third party's question is the easiest and it puts the notions in hand; the Chief Executive Officer's request is the trickiest because it is flattering. For each answer, systematically distinguish what the group CAN prove today, what it WILL be able to prove after this session's state of play, and what belongs to a decision not yet taken. The certification decision itself, with its budget and calendar, will be worked up when the group builds its ISMS, in session 8: today's answer prepares that decision, it does not steal it. Allow 20 minutes for questions 1 to 3, 10 minutes for questions 4 and 5.



Answer keys and assessment criteria – cliquer pour révéler